Nobody puts Bloodhound in a corner

Infusing attack path management into your identity security operations

Aaron T. Woland, CCIE #20113
Distinguished Engineer, Identity Security
loxx@cisco.com | @aaronwoland | aaronwoland

$whoami

Cisco role:	Distinguished Engineer, Identity Security
What do I do:	Focus on New Stuff, have all Identity at Cisco
Experience:	Old enough to wonder how I have been doing this for >30 years
Cyber & ID:	Focus has been on ID, with a strong Cyber Security slant (Masters Degree from SANS)
Fun fact 1:	Father of 5 daughters
Fun fact 2:	Oldest is an SE at Cisco with Wi-Fi specialty

Cisco Confidential

Agenda

01 Our Journey with Bloodhound Enterprise

02 Attack Paths, Meet ISPM (and IVIP)

03 The SIEM is the starting point for the SOC

04 Examining an Attack

05 Parting thoughts

Cisco & identity

**** A long history – you might not associate Cisco with "identity", but you should!**

- Back in the 1990's, Cisco was everywhere as the Internet became a thing.
  - I was working at an ISP back then and was introduced to a little AAA server known as Cisco Access Control Server (ACS).
  - ACS was the quintessential AAA server forever! Dealing with Authenticating identity, Authorizing access & Accounting for the results and activities of users – including 802.1X (port-access control in networking)
  - In 2002, Cisco introduced the world to Network Admission Control (aka: NAC)
- In 2011, we released "project positron" to the world, known as the Identity Services Engine (ISE) the #1 deployed NAC solution in the world
  - In 2018 we acquired Duo: started as world's best MFA, transitioning to SSO, Zero Trust Access, & Passwordless, and a full security-first IDP & acquiring Oort for Identity Intelligence/ISPM/ITDR/IVIP capabilities.
  - Revolutionized ZTNA with Secure Access, leveraging QUIC & MASQUE transport along-side Apple & Samsung.

[**this is not a pitch for Cisco; it's purely for perspective and context relative to Cisco's vision for security]

Cisco Confidential

01 - Our Journey with Bloodhound Enterprise

Our journey to including bloodhound enterprise

How & why Cisco included Bloodhound Enterprise as a strategic partner in its Security & SOC solutions

- Acquire Oort
- Cisco IT asks us to look at Bloodhound
- Cisco invests in SpectreOps
- Bloodhound ENT added to Cisco Pricebook
- Bloodhound ENT integration to CII

Cisco IT has an extensive, long-lived, and many would say very complicated and ugly Active Directory environment.

Cisco is also a constant target-of-choice for attackers.

Identity Intelligence *was* focused on Modern-Auth first, not AD.

Bloodhound was seen as the defacto solution for AD posture

Cisco Confidential

The reality of identity security

- Identity visibility is hard
- Identity posture & hygiene is even **harder**
  - How many orgs proactively initiate identity posture improvement projects? (outside of MFA)
    - How many do it programmatically?
    - Account lifecycle mgmt. is usually chewing gum and duct tape

- In security, TD&R is fundamentally sexier
- "Assume breach" effectively guarantees that orgs will put the "detection & response cart" before the "identity & protect horse"
- TD&R platforms (mostly) do not natively understand posture or static identity security

Cisco Confidential

Identity Security Posture Management (ISPM)

Now: Identity Visibility Intelligence Platform (IVIP)

ISPM / IVIP

Proactive Security

Data sources

Identity providers

okta, G, DUO

HRIS

SAP SuccessFactors

Device Managers

Applications

GitHub, salesforce, aws

Threat Feeds

ipinfo.io, STIX

Static data

Users, Groups, Apps, Devices, Factors, Auth Events, Change Logs

Event streaming

Posture Management

Unified view across all integrated sources

Auth gaps, Weak MFA, leaked passwords

Unified view of all users and devices

Take action

Cisco Security

DUO, Secure Access, XDR, Firewall

ITSM

now

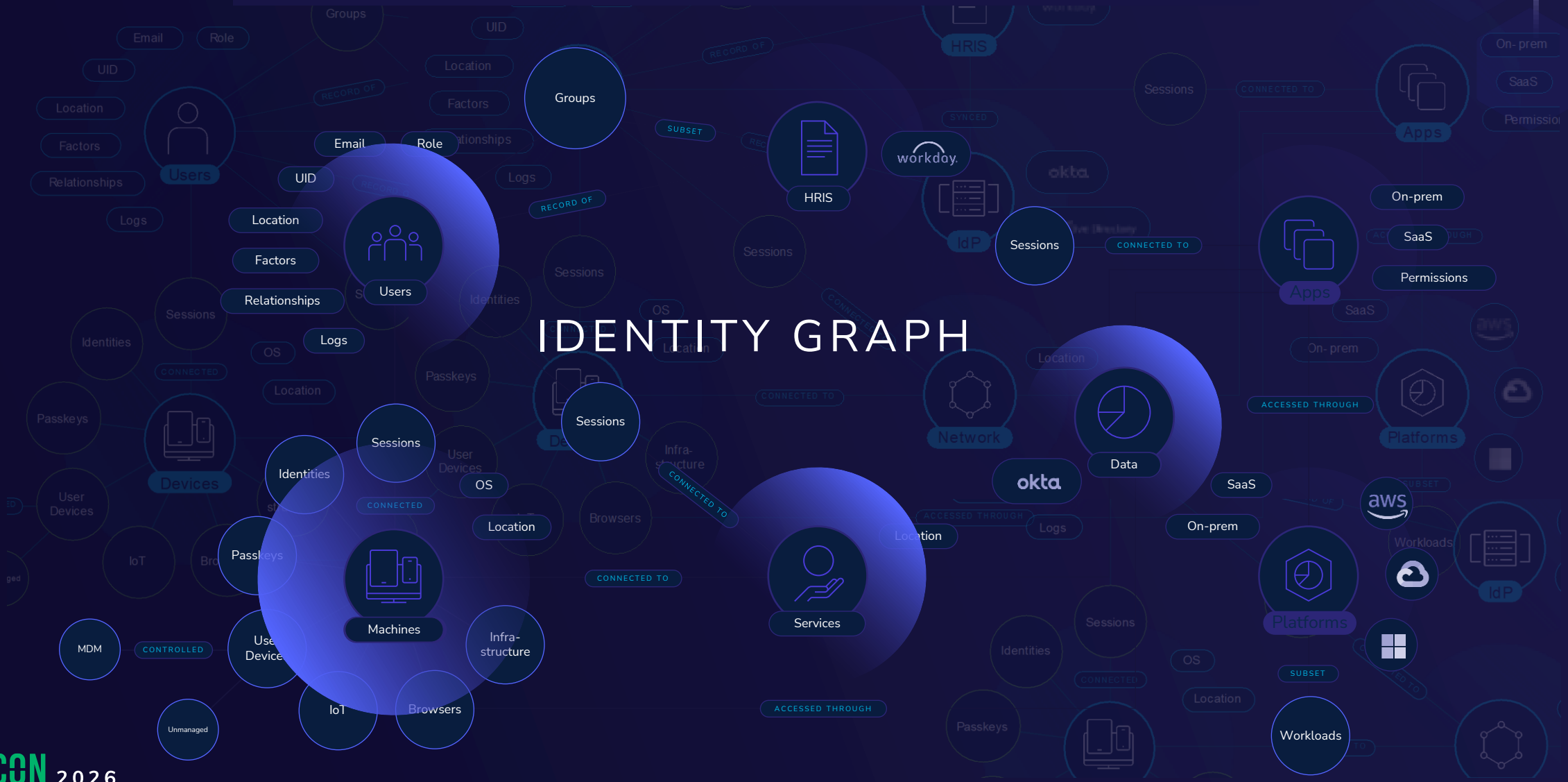
Instant Messaging Platforms

Mitigation Remediation

okta

Cisco Confidential

Cross-Platform Insights in CII



Cisco Confidential

02 - Attack Paths, Meet ISPM (and IVIP)

BHE Attack Paths in the ISPM realm

Findings -> Correlation

- Ingest BHE attack path findings
- Tie them to existing IDP users

Upon review

- Observe that Priority (admin, VIP) accounts have outstanding attack paths
- Quickly see the BHE findings in the side drawer

Identity Intelligence

Checks > Attack Path Alert

Attack Path Alert Moderate

Details

Detects users that appear on identity-based attack paths.

Attack paths represent sequences of relationships that could allow adversaries to escalate privileges or reach high-value assets.

Recommended Actions

Validate the attack path details and remove excessive privileges or risky relationships involved in the path. Prioritize users with high impact or exposure.

Automated notifications for this check are not configured.
Please configure notifications if you wish to receive automated reports about users failing this check.

15 failing users

User	Priority Account	First Observed (UTC)	Admin Notified
aawoland@securitydemo.net	Priority Account	Apr 2, 2026 19:13:07	1 Latest Apr 2, 2026
andy@securitydemo.net	Priority Account	Apr 2, 2026 19:13:25	1 Latest Apr 2, 2026

Attack Path Alert
aawoland@securitydemo.net

Validate the attack path details and remove excessive privileges or risky relationships involved in the path

User Title	Hand of the King
User Trust Level	UNKNOWN

Attack Paths


```
▼ 0:
    accepted: false
    attack_id: 3048
    created_at: "2026-04-02T17:27:59.548Z"
    domain_sid: "S-1-5-21-3303766414-2447965231-3947416167"
    exposure_count: 55
    exposure_percentage: 0
    finding: "T0SyncedToADUser"
    finding_title: "Non-Tier Zero Entra User Synced to Tier Zero AD User"
    from_principal: "7069CEBB-CABD-4BA6-B416-50189B6C91B1"
    impact_count: 20613
    impact_percentage: 1
    severity: "low"
    to_principal: "S-1-5-21-3303766414-2447965231-3947416167-1105"
    updated_at: "2026-04-14T16:51:35.251Z"
▼ 1:
    accepted: false
    attack_id: 3887
    created_at: "2026-03-11T16:48:32.309Z"
    domain_sid: "S-1-5-21-3303766414-2447965231-3947416167"
    finding: "T0MarkSensitive"
    finding_title: "Tier Zero Objects Lack Kerberos Delegation Protection"
    impact_count: 20613
    impact_percentage: 1
    principal: "S-1-5-21-3303766414-2447965231-3947416167-1105"
    severity: "critical"
    updated_at: "2026-04-14T16:51:35.328Z"
```

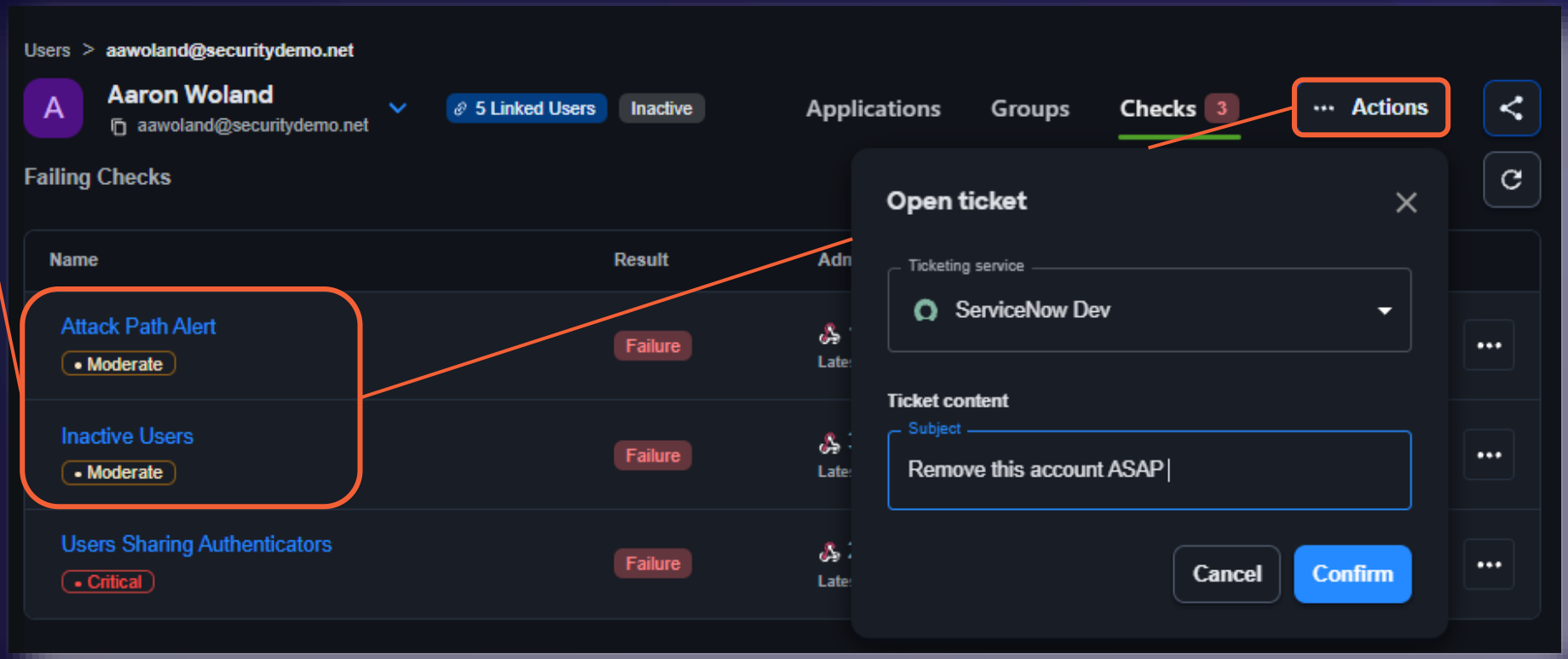

Cisco Confidential

BHE Attack Paths + ISPM Pt 2

-> Investigation -> Action

Further analysis

- User is also Inactive
- Open a ticket to disable or remove the account
- Improve security posture and remove risk in one action



Cisco Confidential

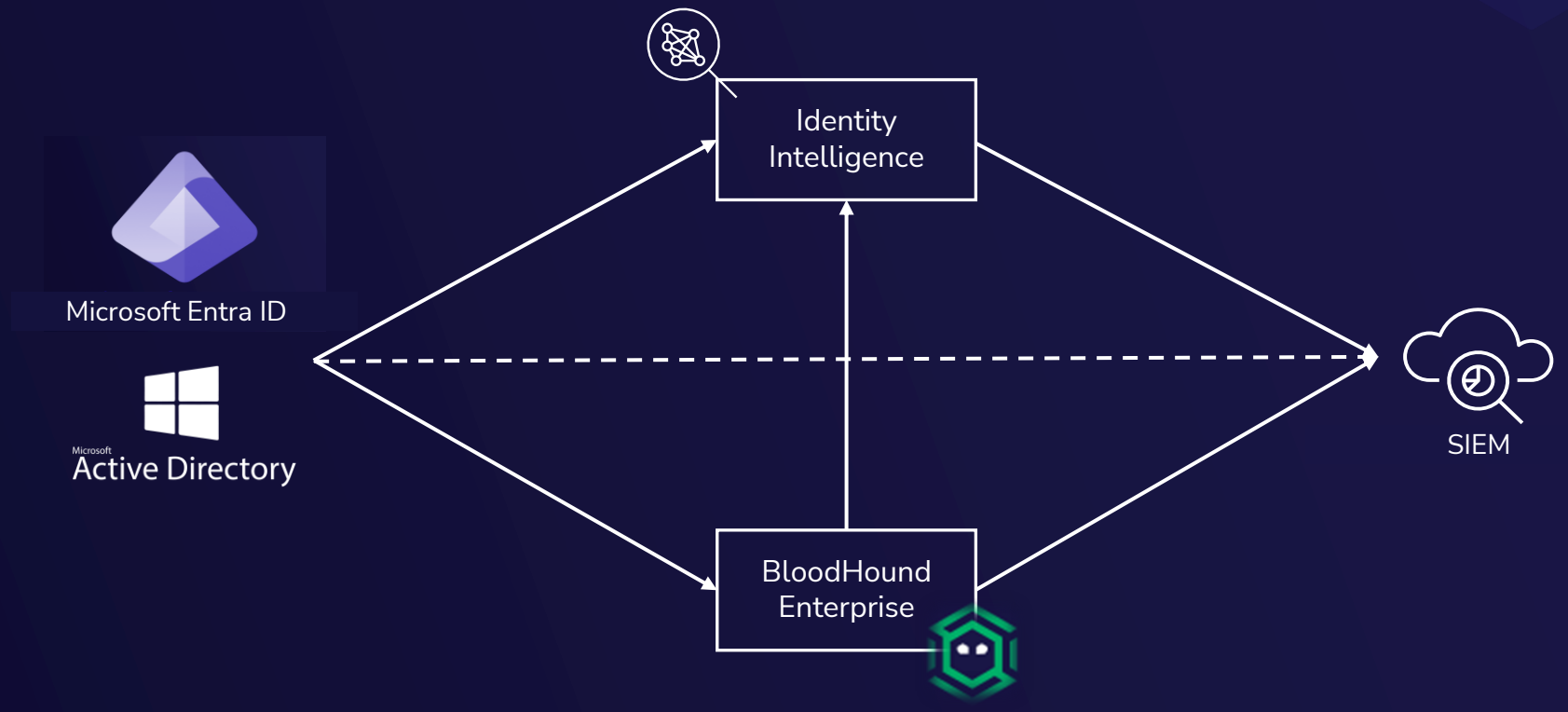
Tie [all] the things together

But what are the things?

- Directories
- BHE
- ISPM / ITDR (CII)
- SIEM (Splunk)

[rhetorical]

- What do we get out of the each of them?
- Is the sum greater than the parts?



Cisco Confidential

Starting Point: SIEM connector apps

Get data flowing

Data Integrity | Resource Utilization | Alerts & Detection | Application Setup | App Analytics

Cisco Identity Intelligence
Overview

Time Range: Previous month | Index: All (1) | Severity: All | Framework: All | Title: All | Type: FAILED_CHECK | Check T: All

Users with most amount of failed checks

User
N/A
loxx@securitydemo.net
carco@securitydemo.net
avikn@en.securitydemo.net
eden@securitydemo.net

Posture | Attack Paths | Audit Logs | Tier Zero Assets | Search | Administration

Attack Path Details

BHE Tenant: ALL × | Environment: SECURITYDEMO.NET × SECURITY DEMO × | Attack Paths: ALL × | Severity: ALL × | Time Range: Last 30 days | Hide Filters

Principals

	Non Tier Zero Principal	Non-Tier Zero Principal Type	Impacted Principal	Impacted Principal Type	Finding Type
1					Tier Zero Role Activation Does Not Require MFA
2	MATT@SECURITYDEMO.NET	User	MATT@SECURITYDEMO.NET	AZUser	Non-Tier Zero AD User Synced to Tier Zero Entra User
3	NULL	User	LOXX@SECURITYDEMO.NET	AZUser	Non-Tier Zero AD User Synced to Tier Zero Entra User
4	CARCO@SECURITYDEMO.NET	User	CARCO@SECURITYDEMO.NET	AZUser	Non-Tier Zero AD User Synced to Tier Zero Entra User
5	PASSWORD ADMINISTRATOR@SECURITY DEMO	AZRole	JUTHAMAD_CISCO.COM#EXT#@SECURITYDEMONET.ONMICROSOFT.COM	AZUser	Reset a Tier Zero User's Password
6	AUTHENTICATION ADMINISTRATOR@SECURITY DEMO	AZRole	JUTHAMAD_CISCO.COM#EXT#@SECURITYDEMONET.ONMICROSOFT.COM	AZUser	Reset a Tier Zero User's Password

Dashboards

Connector apps build the crucial indices for cross-source searching

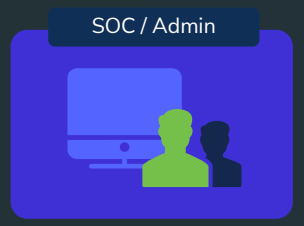
Provide default dashboards for quick platform health and outlier spotting

BHE, Cisco examples

Cisco Confidential

03 - The SIEM is the starting point for the SOC

Investigation timeline – what happened & when?



Responder typically builds out a timeline when investigation

Timeline

Initial Probing

Initial Compromise

Lateral Movement

Data Exfiltration

Pre-Exploitation

Exploitation

Post-Exploitation

Activity

Failed Exploit Attempts

Privilege Escalation

Starting Here, look forward & backwards for correlation to build the timeline / attack graph of "what happened"

Cisco Confidential

IDP matters to the SOC

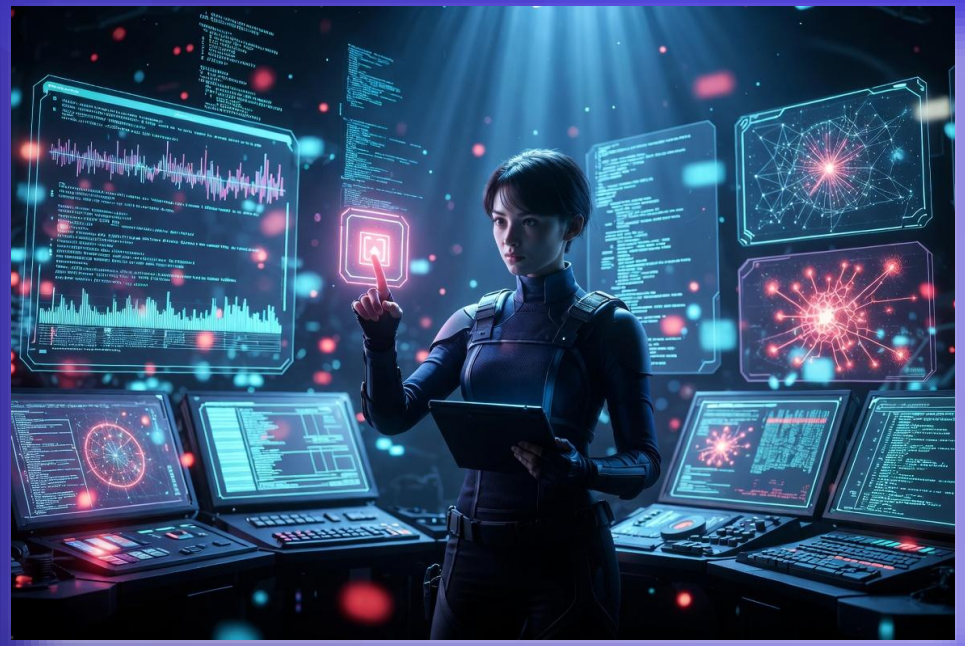
- With Duo Desktop, True binding of the User <> Device.
  - Critical to the SOC to stitch together the timeline of what has happened with the other security products.
- With IDP's, the Auth Logs include:
  - The external IP Address (which is often a NAT pool & often irrelevant to the investigation)
  - The userID (which is VERY relevant to the SOC)
  - The User Agent String (only mildly useful)

MSFT IDP


```
"username": "Loxx"
"useragent": "Chrome"
"ip": "38.64.20.177"
"app": "Bloodhound"
```


Duo w/ Duo Desktop

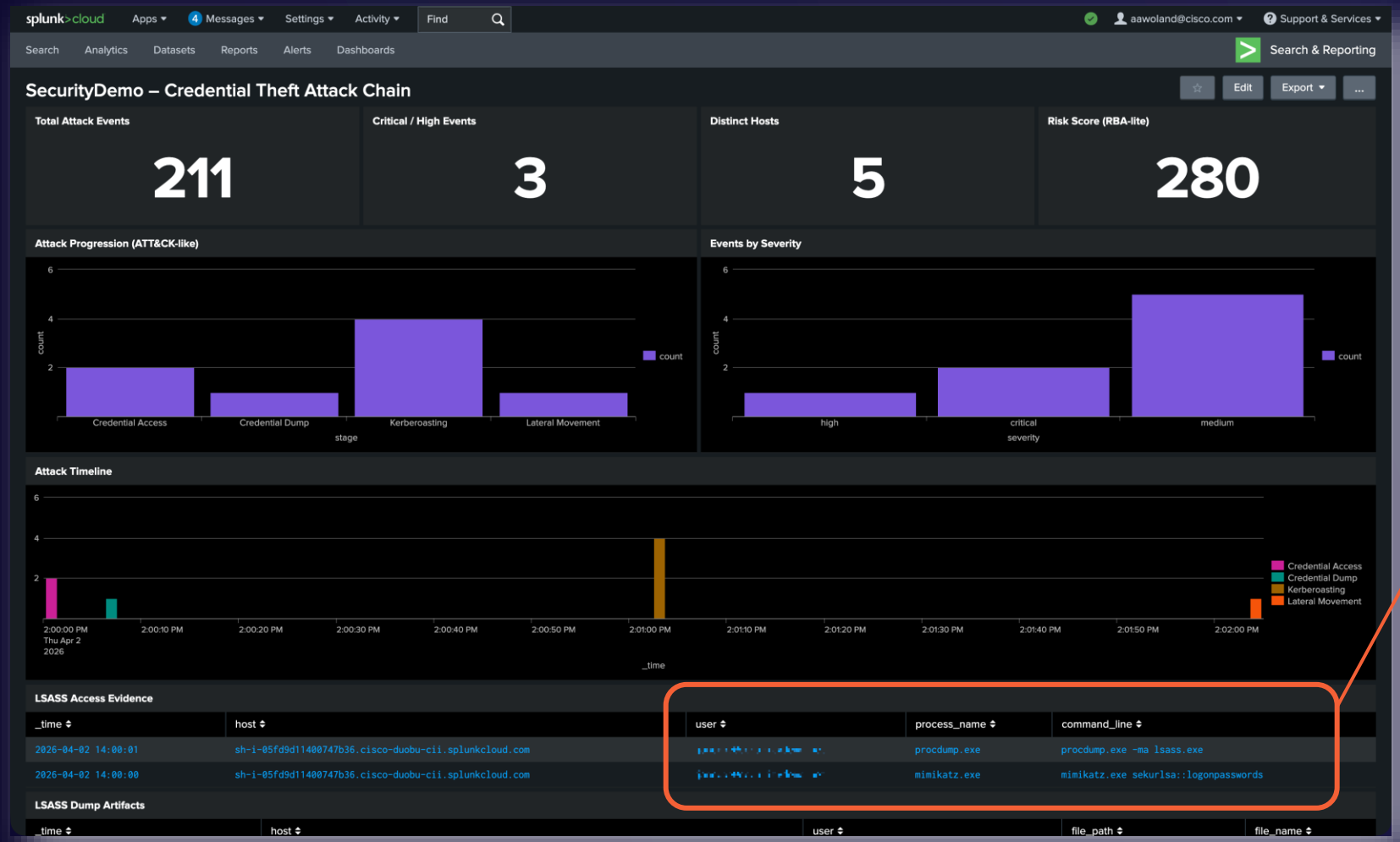

```
"browser": "Chrome",
"hostname": "ATW-WIN10-JUMP",
"ip": "38.64.20.177",
<Posture Details REDACTED>

"machine_guid": "<REDACTED>",

"location": {
        "city": RTP,
        "country": "United States",
        "state": NC },
"adaptive_trust_assessments": {},
"alias": "unknown",
"application": {
"name": "Bloodhound"
},
"passport_assessment": {
        "is_supported": false,
        "reason": "unsigned_health_report"
},
"rbfs_triggered_attacks": null,
"reason": "user_approved",
"result": "success",
"trusted_endpoint_status": "not trusted",
"user": {
"groups": [
        "oort_admins",
        "LabUsers"
],
"name": "loxx"
```



04 - Examining an Attack

The SIEM and/or XDR are the soul of the SOC

This is where the incident response team is going to spend their time & start all responses



Credential Theft

The SOC sees that Jane Doe has been the victim of credential theft via a mimikatz memory dump of LSASS

Has anything else happened with her credentials?

Cisco Confidential

Review AD risks

Quickly check Bloodhound

Multiple findings

In the time frame of the incident

Critical Severity

We know we have significant investigation required in BHE, AD, and endpoints

splunk>cloud | Apps | 6 Messages | Settings | Activity | Find

Search | Analytics | Datasets | Reports | Alerts | Dashboards | Modules

New Search | SPL | Convert to SPL2

```
index=* user="[redacted]" sourcetype="BHE:attack_paths"
```

✓ 24 events (4/1/26 12:00:00.000 AM to 4/7/26 12:00:00.000 AM) | No Event Sampling

Events (24) | Patterns | Statistics | Visualization

Timeline format | – Zoom Out | + Zoom to Selection | × Deselect

Format | Show: 50 Per Page | View: List

Hide Fields | All Fields

SELECTED FIELDS
- host 1
- source 1
- sourcetype 1

INTERESTING FIELDS
- Accepted 1
- AcceptedUntil 1
- admincount 1
- AssetGroupTagID 1
- created_at 1
- deleted_at_Time 1
- deleted_at_Valid 1
- deleted_at_Time 1
- deleted_at_Valid 1
- distinguishedname 1
- domain 1
- domain_name 1
- DomainSID 1
- domainsid 1
- dontreqpreauth 1
- enabled 1
- Environment 1
- eventtype 1

Time	Event
4/6/26 11:20:17.000 PM	

```
{ [-]
  Accepted: false
  AcceptedUntil: 0001-01-01T00:00:00Z
  AssetGroupTagID: 1
  DomainSID: S-1-5-21-3303766414-2447965231-3947416167
  Environment: SECURITYDEMO.NET
  Finding: T0MarkSensitive
  ImpactCount: 20613
  ImpactPercentage: 0.99985
  Principal: S-1-5-21-3303766414-2447965231-3947416167-1175
  PrincipalKind: User
  PrincipalName: [redacted]
  Props: { [+]
  }
  Severity: critical
  created_at: 2026-04-02T17:44:18.594063Z
  deleted_at: { [+]
  }
  domain_name: SECURITYDEMO.NET
  id: 4165
  path_title: Tier Zero Objects Lack Kerberos Delegation Protection
  remediation: https://playground.bloodhoundenterprise.io/ui/remediation?findingType=T0MarkSensitive
  source_domain: https://playground.bloodhoundenterprise.io
  updated_at: 2026-04-07T03:15:17.770244Z
}
```


Cisco Confidential

Is there a larger blast radius?

Review the identity posture

Identity Intelligence

Users > [redacted]

Jane Doe [redacted] Active | Significant Change

Overview | Activity | Networks

Summary

- Internal, Active
- N/A
- N/A
- N/A
- N/A
- MFA Configured
- Mar 18, 2026 18:29:54 UTC (22 days ago)
- N/A
- Significant Change Admin role assigned on Apr 3, 2026

Created Jan 15, 2026

Last Login Attempt | View more data

SecDemoAD

Jane Doe [redacted] Active | Local

Trust Level

Questionable

The level changed from Untrusted to Questionable on Apr 7, 2026 23:58:59 UTC because of the following fact

Search by device keys or values

Source	SecDemoAD	SecurityDemoNet-Azure
Status	Active	Enabled
Display Name	Jane Doe [redacted]	Jane Doe [redacted]
Failing Checks	N/A	Admin Role Assigned to User
Created At	Mar 3, 2026	Mar 12, 2026
User Keys	jan[redacted]et d82/szdm70a38gpsugd8cq== cn=jane doe,cn=users,dc=sec...	[redacted] jane smi[redacted]demonet.o... smi[redacted]o.net 2ec7140e-26cc-455f-bdc5-0e4...

Additional anomalies

ISPM identifies an unusual privileged role assignment in Entra ID

Cisco Confidential

Digging into the details

How in the world??

Easily identifiable

Pivot to quickly investigate the privilege escalation in Entra ID

Admin Role Assigned to User (Latest event: 6 days ago)

Ensure this assignment was legitimate. If the target should not be an administrator or should not be assigned that role, please start an investigation and create a ticket.

Providers failing check	SecurityDemoNet-Azure
User Trust Level	QUESTIONABLE
Initiated By	Andy Winiarski
Roles	

```
0: "Global Secure Access Administrator"
```

Self Assigned	false
Activity targets	
Other	Global Secure Access Administrator Type: Role
Other	Security Demo Type: Directory
Other	Security Demo Type: Directory
User	Jane Doe
Other	5a876dd8-942e-43b4-a4cc-4eb9d02d0e33__AZURE_AD__c02023d2__Request__d03b7b05-ccda-41a3-98fb-6594b4af8a7f Type: Request
Other	5a876dd8-942e-43b4-a4cc-4eb9d02d0e33__AZURE_AD__c02023d2__Other__00000000-0000-0000-0000-000000000001 Type: Other

2 events found View in user activity

Date (UTC)	Source	Event	Result	
Apr 3, 2026 00:27:28		Add eligible member to role in PIM completed (permanent)	Success	See in context
Apr 3, 2026 00:27:27		Add eligible member to role in PIM requested (permanent)	Success	See in context

Cisco Confidential

Leading us back to BHE

Clear next step

In addition to the anomalous Entra actions, this user also has active AD attack paths

Admin Role Assigned to User (Latest event: 6 days ago)

Ensure this assignment was legitimate. If the target should not be an administrator or should not be assigned that role, please start an investigation and create a ticket.

Providers failing check	SecurityDemoNet-Azure
User Trust Level	QUESTIONABLE
Initiated By	Andy Winiarski
Roles	

Identity Intelligence

Users > jane@securitydemo.net > jane@securitydemo.net > andy@securitydemo.net

A **Andy Winiarski** Active
andy@securitydemo.net

Failing Checks

Name	Result	Times Excluded	First
Attack Path Alert • Moderate	Failure	0	Apr
Microsoft Entra ID Admin Activity Anomaly • Low	Failure	0	Apr

Observed At	Source	Feedback Provided
Apr 3, 2026 01:41:34		N/A
Apr 3, 2026 01:41:34		N/A
Apr 2, 2026 22:41:44		N/A
Apr 2, 2026 17:41:01		N/A

Resolved Checks

Attack Path Alert

Validate the attack path details and remove excessive privileges or risky relationships involved in the path

User Title	Loose Cannon
User Trust Level	QUESTIONABLE

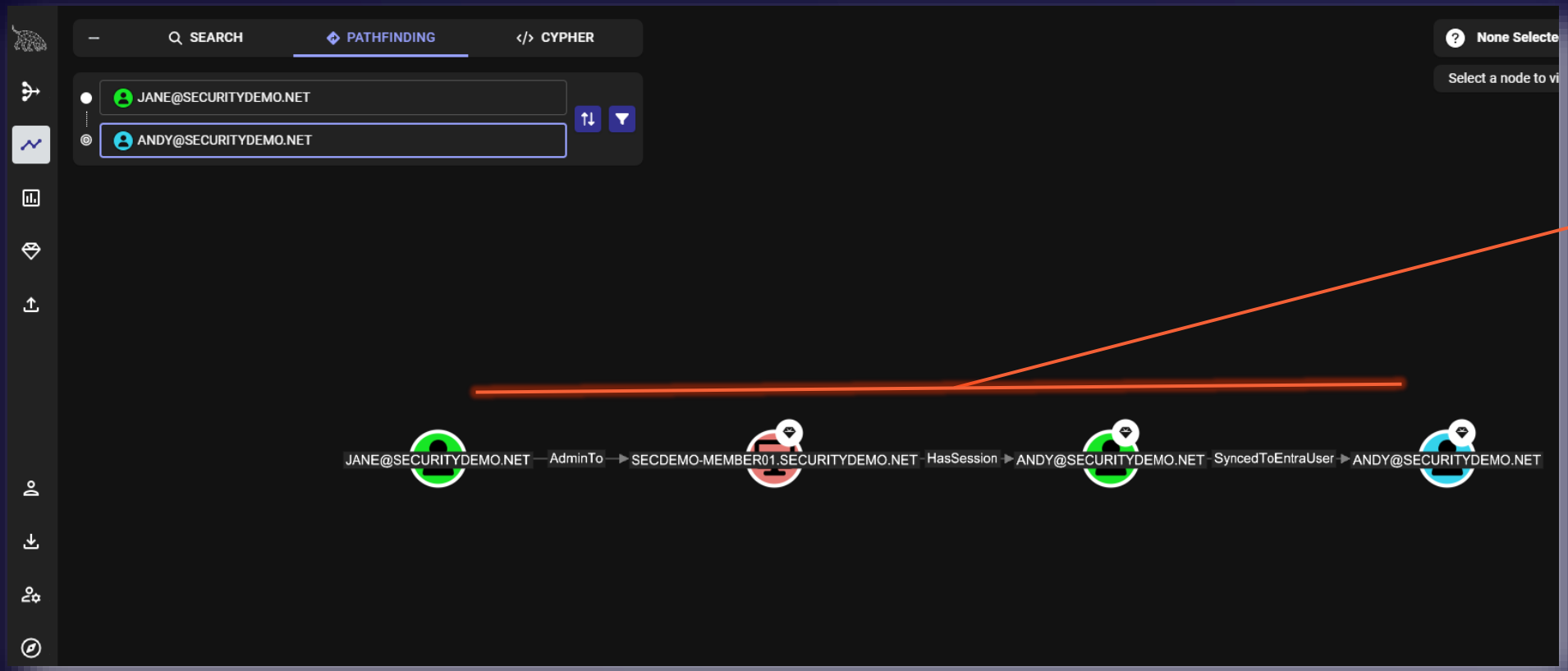
Attack Paths


```
▼ 0:
    accepted: false
    attack_id: 3884
    created_at: "2026-03-11T16:48:32.304Z"
    domain_sid: "S-1-5-21-3303766414-2447965231-3947416167"
    finding: "T0MarkSensitive"
    finding_title: "Tier Zero Objects Lack Kerberos Delegation Protection"
    impact_count: 20613
    impact_percentage: 1
    principal: "S-1-5-21-3303766414-2447965231-3947416167-1117"
    severity: "critical"
    updated_at: "2026-04-08T16:51:55.750Z"
▼ 1:
    accepted: false
    attack_id: 2934
    created_at: "2026-03-24T15:50:52.657Z"
    domain_sid: "S-1-5-21-3303766414-2447965231-3947416167"
    exposure_count: 4
    exposure_percentage: 0
    finding: "T0Logins"
    finding_title: "Logons From Tier Zero Users"
    from_principal: "S-1-5-21-3303766414-2447965231-3947416167-2101"
```


Cisco Confidential

BHE pathfinding at its simplest (and best)

Lateral to hybrid movement



The path continues

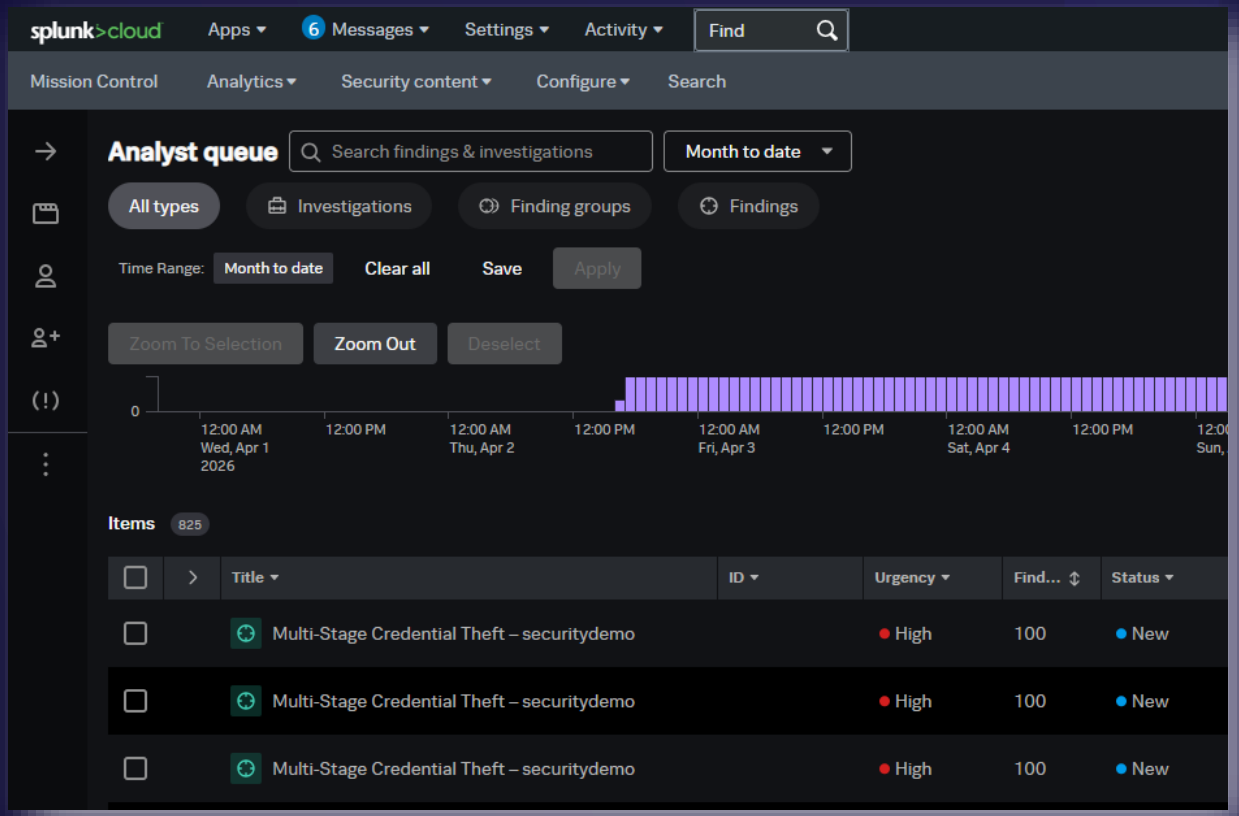
From here, clearly there is much response and remediation work to be done

Cisco Confidential

Containment & Remediation

Myriad of options

- We have a solid starting list of principals and objects
- Pivoting back to SIEM / XDR / EDR and playbooks or automations
  - Removing the attack paths
  - Resetting credentials
    - Primary & Secondary Factors
  - Removing old & expired accounts
  - So much more…



Cisco Confidential

05 - Parting thoughts

Tying these tools together made it easier and faster to see the attacker's movements across platforms, with a more comprehensive view of critical attack details that may have overlooked or missing in any one tool alone.

Cisco Confidential

Please fill out the Survey

Nobody Puts BloodHound in a Corner: Infusing APM into Your Identity Protection Strategy

If there is anything we can improve, please let us know!

Thank you

Nobody Puts BloodHound in a Corner: Infusing APM into Your Identity Protection Strategy